
papAI

PAS - Plan Assurance Sécurité

Datategy

2022-01-30

Table des matières

1	Introduction	1
1.1	Politique de sécurité de l'information	1
1.2	Revue de la PSSI	1
2	Gestion des risques	3
3	Gestion des incidents liés à la sécurité	4
4	Gestion des ressources humaines	5
4.1	Embauche	5
4.2	Confidentialité	5
4.3	Départ	5
5	Gestion de l'exploitation	6
5.1	Contrôle d'accès	6
5.1.1	Politique de mot de passe	6
5.1.2	Gestion des droits d'accès	6
5.2	Infrastructure	7
5.2.1	Sauvegarde	7
5.2.2	Surveillance	7
5.3	Cryptographie	7
5.3.1	Données en transit	7
5.3.2	Certificats	7
6	Sécurité logicielle	9
6.1	Injection de code	9
6.2	Vulnérabilités connues des composants	9
6.3	Sécurité du développement	9
7	Réversibilité	10

1 Introduction

1.1 Politique de sécurité de l'information

Les activités papAI SaaS sont encadrées par une PSSI (Politique de Sécurité des Systèmes d'Information). Cette PSSI est formalisée et encadrée par la direction générale de l'entreprise. Cette PSSI fixe le périmètre, les principes de mise en œuvre ainsi que les responsabilités nécessaires pour assurer une protection appropriée des systèmes d'information de l'entreprise. L'ensemble des salariés de l'entreprise s'engage à respecter la PSSI qui est disponible sur le référentiel des documents de l'entreprise.

La PSSI est confidentielle.

Le présent document PAS (Plan Assurance Sécurité) en reprend les informations communicables et décrit les engagements de Datategy et les solutions mises en œuvre afin de protéger la disponibilité, l'intégrité et la confidentialité de la solution papAI.

Protéger la confidentialité des données en toutes circonstances est au cœur de la démarche sécurité de Datategy.

L'équipe Datategy s'engage à innover de façon permanente pour répondre aux besoins en constante évolution des clients en termes de technologie, de fonctionnalités et de performances. La sécurité est intégrée dans le cycle de vie du développement de la solution papAI.

1.2 Revue de la PSSI

La PSSI est révisée au minimum annuellement afin qu'elle soit en adéquation avec les évolutions de l'entreprise (organisation, missions, périmètre, axes stratégiques, valeurs). Le système d'information (SI) peut être l'objet de modifications, tout comme les menaces et vulnérabilités qui s'y appliquent. Il convient alors de prévoir un réexamen de la PSSI :

- lors de toute évolution majeure du contexte ou du SI ;
- dans le cas d'une évolution de la menace ;
- dans le cas d'une évolution des besoins de sécurité ;

- à la suite d'un audit ;
- à la suite d'un incident de sécurité ;
- systématiquement une fois par an ;
- sur demande d'une autorité.

2 Gestion des risques

La direction générale de Datategy se porte garante du maintien du SMSI (Système de Management de la Sécurité de l'Information) relative aux exigences de la norme ISO/IEC 27001.

La politique et les objectifs du SMSI ont été clairement établis et communiqués aux rôles définis au sein du SMSI, afin de prendre en compte les principaux risques identifiés :

- Risque d'indisponibilité des informations et applications, et des systèmes les traitant
- Risque de divulgation, ou perte de confidentialité, accidentelle ou volontaire des informations
- Risque d'altération, ou perte d'intégrité, qui pourrait conduire à une perte d'information Client

Une étude des risques a été conduite selon la méthode EBIOS (Expression des Besoins et Identification des Objectifs de Sécurité) maintenue par l'ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information). Cette étude a conduit à un plan d'actions d'évolution des mesures de sécurité dans les pratiques de développements.

La mise en œuvre du SMSI a pour objectif de :

- Améliorer et formaliser la gestion de la sécurité de la solution papAI
- Créer une culture de la sécurité auprès des équipes Datategy
- Étendre les bonnes pratiques à tous les services proposés par Datategy
- S'assurer du respect par Datategy de ses obligations légales en ce qui concerne la gestion des Données Personnelles (Loi Informatique et Libertés, RGPD)

3 Gestion des incidents liés à la sécurité

Datategy s'engage à communiquer sur toute faille qui serait susceptible d'avoir compromis l'intégrité de la solution papAI ou la confidentialité des données.

Le signalement des incidents et leur enregistrement sont systématiques. Une procédure décrit les escalades et personnes à alerter selon la gravité de l'incident.

Un incident de type violation de Données Personnelles respecte les obligations liées au RGPD et peut faire l'objet d'une notification à la CNIL selon les cas.

Un groupe de gestion de sécurité sera créé afin de coordonner les efforts de Datategy et du Client dans la gestion de l'incident.

4 Gestion des ressources humaines

4.1 Embauche

Un projet « onboarding » structure l'intégration de tout nouveau collaborateur. Les droits d'accès aux informations, aux applications et aux serveurs sont définis par les rôles et affectations projet des collaborateurs. Le projet d'accueil prévoit également une sensibilisation à la sécurité et aux bonnes pratiques à appliquer.

4.2 Confidentialité

Tout collaborateur Datategy signe une clause de confidentialité dans son contrat de travail.

Tout collaborateur de Datategy prend connaissance de la charte informatique, le signe et s'engage à la respecter et à la faire respecter. Cette charte fait également référence aux obligations de confidentialité, et définit les règles de bon usage des ressources informatiques et numériques mises à disposition.

4.3 Départ

Un projet « offboarding » structure les actions à mener au départ de tout collaborateur, et en particulier la fermeture de ses comptes d'accès aux différentes ressources.

5 Gestion de l'exploitation

Durant la période d'abonnement au service, la plateforme papAI sera amenée à évoluer fonctionnellement et techniquement. En effet, de manière régulière, de nouvelles fonctionnalités sont ajoutées et profitent à l'ensemble des clients de Datategy.

Ces nouvelles fonctionnalités sont en général mises à disposition gratuitement dans le cadre de la redevance annuelle de l'abonnement à la plateforme.

5.1 Contrôle d'accès

5.1.1 Politique de mot de passe

Chaque utilisateur est identifié par un identifiant unique et un mot de passe fort répondant aux exigences minimales de la CNIL

- Non-trivialité
- Taille minimale de 8 caractères
- Utilisation de caractères alphanumériques et de caractères spéciaux

Les mots de passe sont personnels et confidentiels, ils ne sont donc pas stockés par les équipes techniques Datategy.

Les mots de passe sont stockés dans une base sécurisée et chiffrée par un coffre-fort Hashicorp Vault.

5.1.2 Gestion des droits d'accès

L'administration courante des environnements managés est réalisée par les équipes Datategy par l'intermédiaire de comptes d'administration aux droits limités. L'accès par les autres personnels techniques n'est autorisé que pour la durée d'affectation ou d'intervention prévue.

L'ensemble des serveurs n'est accessible en SSH que depuis une liste fermée d'adresses IP Datategy.

L'administration d'un serveur dédié à un Client, qui est totalement étanche vis-à-vis des autres serveurs dédiés, peut être sous la responsabilité du Client, ou celle d'un Tiers de son choix. Dans ce cas la sécurité du Système d'Information spécifique est sous son entière responsabilité.

5.2 Infrastructure

5.2.1 Sauvegarde

Une sauvegarde journalière des serveurs virtualisés des instance managées est effectuée, copiée et conservée 7 jours (Stockage chaud sécurisé). Ces sauvegardes permettent une remise en place d'une instance papAI à une date passée, dans la limite de la semaine.

Une copie hebdomadaire stockée 1 mois, et 12 copies mensuelles stockées un an sont ensuite effectuées (Stockage froid sécurisé). Les sauvegardes sont compressées et chiffrées. La base de données sauvegardé est également chiffrée.

Des tests de restauration sont effectués très régulièrement selon un planning préétabli.

5.2.2 Surveillance

Les serveurs sont placés sous surveillance constante par collecte de données de production en temps réel : CPU, Entrées sorties, Mémoire, et tout dépassement de seuils déclenche l'envoi d'une alerte mail.

5.3 Cryptographie

5.3.1 Données en transit

Tout transfert de données en dehors de notre infrastructure sont systématiquement chiffrés SSL / TLS, garantissant que les paquets de données en transit ne peuvent pas être falsifiés ou lus même s'ils sont interceptés.

5.3.2 Certificats

Les certificats utilisés par les équipes techniques Datategy proviennent d'autorités de certifications publiques et reconnues.

- Compatible avec les protocoles TLS 1.3 et TLS 1.2
- Clé RSA de 2048 bits
- Signature : SHA256withRSA

Pour les déploiements on-premises, chaque client est responsable de fournir à Datategy les certificats permettant la mise en œuvre des protocoles sécurisés.

Suivant les contraintes internes de chaque Client, plusieurs solutions peuvent être proposées pour mettre en place ces solutions y compris sur un sous domaine du Client.

6 Sécurité logicielle

Les développements internes incorporent les bonnes pratiques suggérées par la fondation OWASP (Open Web Application Security Project).

6.1 Injection de code

Les requêtes SQL sont paramétrées par des variables utilisant les notations recommandées, où les variables sont validées afin de détecter entre autres la présence de caractères interprétés par les moteurs de base de données.

Les objets JSON et les données numériques sont analysés et convertis à l'aide de fonctions natives.

6.2 Vulnérabilités connues des composants

Différents outils d'audit additionnels sont utilisés tout au long du cycle de développement et d'évolution de la plateforme.

- Scan Librairies : Les dépendances Scala, Python et JavaScript sont analysées et confrontées aux référentiels de vulnérabilités connues CVE (Common Vulnerabilities and Exposures). Un outil d'audit différent est appliqué pour chaque langage utilisé.
- Scan Conteneurs : Les applications conteneurisées sont scannées par l'intermédiaire de Snyk qui complète les référentiels CVE par un référentiel propriétaire.
- Scan Infrastructure : Les configurations Docker sont scannées et confrontées au référentiel de bonnes pratiques CIS benchmark Docker (Center for Internet Security). On citera par exemple l'usage de l'outil open-source Docker Bench.

6.3 Sécurité du développement

Les développements sont déployés en suivant un processus de validation en mode Intégration Continue : tests unitaires, tests de qualité de code, tests de maintenabilité, tests de scénarios utilisateurs.

7 Réversibilité

Datategy s'engage à fournir au Client les Informations gérées par ses plateformes, et à garantir, lors du transfert, la sécurité des données qui lui ont été confiées, conformément à ses obligations.

En cas d'arrêt des prestations confiées, l'ensemble des Informations sera restitué.

Tous les actifs produits par la plateforme, propriété du Client, sont identifiés et inventoriés. Les actifs de la plateforme sont basés sur des formats ouverts et standards.

La réversibilité de ses actifs se fera vers le serveur désigné par le Client par copie SFTP ou FTPS :

- Scripts Python, R, SQL
- Extensions
- Dump SQL sécurisé de toutes les données de gestion
- Modèles d'IA entraînés
- Échantillons de données physiques